

IT Security Policy/Procedures

Introduction

With recent incidents involving lost or misplaced Universal Serial Bus (USB) drives containing sensitive company data, the organization faces a growing concern regarding asset protection, data protection, and accountability. One recently turned in device was discovered to contain several sensitive financial documents while another was misplaced pending recovery. These situations pose a severe risk to the company's integrity and reputation. The purpose of this document is to identify the risks involved, outline applicable legal and regulatory standards, and finally, establish mitigation strategies to ensure removable media is handled securely and in compliance with both company policy and industry standards.

Key Risks

1. **Data Exposure:** Lost or stolen removable drives containing unencrypted information can result in unauthorized disclosure of proprietary or client data.
2. **Malware Threats:** USB drives used on external or personal computers can introduce malicious software into company systems.
3. **Untracked Usage:** Without monitoring or auditing, it becomes impossible to identify which files were stored on or transferred through a removable device.
4. **Insider Threats:** Employees may unintentionally or deliberately copy sensitive data to removable drives without proper authorization.
5. **Noncompliance:** Unsecured storage devices could violate company policy or federal data protection standards, leading to financial and legal consequences.

Legal Considerations

1. **United States Considerations:**
 - a. *Federal Information Security Modernization Act (FISMA)*: Requires secure handling and protection of sensitive information within federal systems and affiliated organizations.
 - b. *Sarbanes-Oxley Act (SOX)*: Mandates proper safeguarding traceability of financial data which prevents tampering or unauthorized disclosure.

2. **Client Considerations:** Client contracts require encryption and strict control over portable storage to maintain confidentiality.
3. **Contractual Obligations:** Failure to comply with data-handling obligations may result in legal penalties, financial losses, and reputational damages.

Mitigation Strategies

1. **Concern:** Data Exposure
 - a. **Correction:** All removable media must be encrypted using approved software such as BitLocker To Go. Encryption keys will be securely stored within company-managed directories, ensuring that lost drives cannot be accessed by unauthorized parties.
2. **Concern:** Malware Threats
 - a. **Correction:** Company systems will automatically scan all removable drives using updated antivirus and endpoint detection tools. AutoRun and AutoPlay features will remain permanently disabled to prevent automatic execution of malicious files.
3. **Concern:** Untracked Usage
 - a. **Correction:** File activity on removable drives will be logged and monitored. This includes all copy, write, and delete operations. Audit logs will be reviewed by the IT security team to identify suspicious or abnormal behavior.
4. **Concern:** Insider Threats
 - a. **Correction:** Removable media privileges will be limited to employees with a verified business need. Access will be controlled through Active Directory group policies, and any exception must be approved by the IT Security Officer.
5. **Concern:** Noncompliance
 - a. **Correction:** Regular security audits will verify that all removable media follow encryption, logging, and approval requirements. Noncompliance will result in immediate revocation of access and potential disciplinary action.
6. **Concern:** Employee Awareness
 - a. **Correction:** Mandatory cybersecurity training will be provided to all staff, focusing on proper data handling, encryption procedures, and the immediate reporting of lost or misplaced drives. Employees will acknowledge this policy upon completion.

Conclusion

With the increased use of removable media for file transfers and data storage, implementing strict security controls is essential to maintaining confidentiality and integrity across all company systems. Enforcing encryption, monitoring device usage, and limiting access to authorized personnel will minimize the risk of data loss or unauthorized disclosure. Through continued compliance, employee training, and proactive risk management, the company can ensure that all sensitive information remains secure and protected against both internal and external threats.